

# Behavior-Driven Risk-Based Authentication for IoT: A Multi-Layer Machine Learning Framework

Liza Hadjira Batache\*, Melissa Lagab\*, Mohamad Jaafar Ali\*, Osman Salem\*, Ahmed Mehaoua\*

\*Faculty of Fundamental and Biomedical Sciences, Paris Cité University, Paris, France

{liza.batache, melissa.lagab}@etu.u-paris.fr, mohamad.ali@u-paris.fr, osman.salem@u-paris.fr, ahmed.mehaoua@u-paris.fr

**Abstract**—We present a scalable and behavior-driven Risk-Based Authentication (RBA) framework for Internet of Things (IoT) environments. Our approach integrates technical indicators, behavioral consistency, and anomaly detection into a multi-layered risk score. Trained on 500,000 synthetic IoT login sessions, our framework benchmarks eight machine learning classifiers. Ensemble models, such as Random Forest and Gradient Boosting, achieve strong performance ( $F1 \approx 0.99$ ). Using SHAP (SHapley Additive exPlanations)-based explainability, we analyze how contextual and behavioral features influence access decisions. This work supports adaptive, interpretable, and real-time authentication in dynamic and resource-constrained edge IoT ecosystems.

**Index Terms**—Risk-Based Authentication, IoT Security, Machine Learning, SHAP, Anomaly Detection

## I. INTRODUCTION

The rapid growth of the IoT has transformed sectors ranging from healthcare to smart cities. However, this proliferation brings critical authentication challenges due to device heterogeneity, intermittent connectivity, and evolving user behavior. Traditional static mechanisms (e.g., passwords, tokens) are ill-suited to such dynamic environments, as they lack context-awareness and flexibility.

RBA offers a promising alternative by adjusting access control based on contextual and behavioral signals. Combined with Machine Learning (ML), RBA can support real-time anomaly detection and adaptive decision-making. Nevertheless, implementing RBA in IoT environments remains challenging due to resource constraints, device diversity, and the need for scalable, interpretable models.

In this paper, we propose a lightweight and adaptive RBA framework tailored for IoT. Specifically:

- We generate a synthetic dataset of 500,000 IoT login sessions, capturing behavioral, contextual, and technical variations;
- We design a multi-layered risk scoring pipeline that integrates static indicators, behavioral drift, and anomaly flags into a unified Dynamic Risk Score (DRS);
- We benchmark eight ML classifiers over a tri-level access control system (**Allow**, **Challenge**, **Block**) and compare performance with a GitHub RBA baseline;
- We deliver a modular, interpretable, and scalable architecture suitable for real-world IoT deployments.

**Motivation and contribution.** In heterogeneous IoT settings, static credentials fail to adapt to context drift, device churn, and network risk. We contribute a behavior-aware Dynamic

Risk Score (DRS) that fuses technical indicators (IRS), behavioral consistency (BS), and anomaly flags into an interpretable tri-level policy (**Allow/Challenge/Block**). Our focus is IoT edge scenarios where device churn, intermittent connectivity, and heterogeneous stacks make static credentials brittle. By design, the DRS provides a compact, explainable control lever to trade off user friction (Challenge rate) and security (Block recall) under resource constraints.

To our knowledge, this is the first end-to-end behavior-aware RBA simulation for IoT environments. The proposed system lays a foundation for intelligent, adaptive, and context-aware authentication in future connected ecosystems. The remainder of this paper is organized as follows: Section II reviews related work. Section III presents the proposed methodology. Section IV discusses the experimental results. Section V provides a comparative analysis with a baseline system. Section VI concludes the paper and outlines directions for future work. In addition, to address reviewer feedback, we conducted a real-world evaluation on the public TON\_IoT Thermostat dataset, which confirmed that the absence of behavioral and contextual risk layers severely reduces attack detection performance.

## II. RELATED WORK

RBA has emerged as a dynamic alternative to static credentials, particularly in heterogeneous environments like IoT. Traditional methods—passwords, OTPs—are vulnerable to phishing, reuse, and lack the context-awareness required for dynamic ecosystems [1], [2].

Amin et al. [3] introduced a smart-card and biometric scheme, enhancing security at the cost of high energy consumption. Yang et al. [4] leveraged contextual data for mobile authentication but struggled with latency and adaptability. Fridman et al. [5] applied behavioral biometrics (e.g., keystrokes, browsing patterns) on desktop platforms, while Rathore et al. [6] focused on mobile authentication without addressing IoT scalability.

In anomaly detection, Gholamrezaei [11] used logistic regression and random forests on web login logs, omitting IoT-specific constraints. Kitsune [7] presented a lightweight anomaly detector for network traffic but excluded behavioral modeling. Wiefing et al. [8] emphasized the need for explainable RBA, yet most implementations still lack transparency or post-hoc interpretability tools like SHAP or LIME.

Unlike previous works, our approach offers a unified and interpretable RBA framework that combines:

- A synthetic IoT login dataset enriched with behavioral and contextual dimensions;
- A layered scoring mechanism (Initial, Behavioral, Anomaly) forming a DRS;
- A comprehensive multi-class classification pipeline benchmarked against existing baselines.

Table I summarizes the main capabilities of recent RBA frameworks. While prior solutions typically focus on either contextual or anomaly-based factors in isolation, our work uniquely integrates contextual, behavioral, and anomaly-aware indicators into a unified scoring strategy. This comprehensive design, combined with scalable simulation and a rich IoT-specific feature set, enables more accurate and explainable classification. By addressing limitations of past models, we provide a robust foundation for secure and adaptive authentication in dynamic IoT environments.

Few works combine contextual scoring, behavioral drift, and anomaly detection into a single pipeline validated on both synthetic and public IoT datasets. Our approach addresses this gap and introduces explainability tools (SHAP, LIME) for transparency.

TABLE I  
COMPARISON WITH PRIOR RBA WORKS

| Approach           | Context-Aware | ML-Based | IoT-Specific | Anomaly |
|--------------------|---------------|----------|--------------|---------|
| Amin et al. [3]    | ✓             | ✗        | ✗            | ✗       |
| Yang et al. [4]    | ✓             | ✗        | ✗            | ✗       |
| Fridman et al. [5] | ✓             | ✓        | ✗            | ✗       |
| Gholamrezaei [11]  | ✓             | ✓        | ✗            | ✓       |
| Kitsune [7]        | ✗             | ✓        | ✓            | ✓       |
| <b>Our Work</b>    | ✓             | ✓        | ✓            | ✓       |

### III. PROPOSED METHODOLOGY

#### A. Architecture Overview

Our system consists of five modular components: **(1)** Synthetic Data Generation, **(2)** Risk Scoring, **(3)** Anomaly Detection, **(4)** Feature Engineering, and **(5)** Machine Learning Classification.

We generated 500,000 synthetic IoT login sessions based on behavioral and contextual heuristics observed in real-world datasets [1], [4], [11], including device changes, location shifts, Virtual Private Network (VPN) usage, and unusual login times. These simulations capture plausible patterns while maintaining experimental control.

Each login session is evaluated across technical, contextual, and behavioral dimensions. A layered scoring pipeline assigns risk scores that guide the final classification. Fig. 1 illustrates the overall system architecture.

**Detection locus.** Anomaly heuristics and risk scoring are computed *server-side* at the edge gateway (IoT hub) *before* session admission; enforcement happens at the API gateway of the service backend. For constrained devices unable to run

local checks, raw context is forwarded to the edge for scoring; otherwise, lightweight pre-checks (e.g., device fingerprint, coarse geolocation) may run on-device and be included in the request metadata. This clarifies where and at which layer detection occurs.

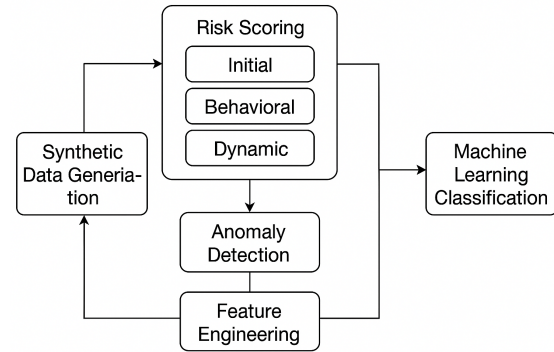


Fig. 1. System Architecture for Risk-Based Authentication

#### B. Feature Engineering

To represent IoT login context, over 25 features are extracted and grouped as follows:

- **User metadata:** age, domain, historical activity
- **Device attributes:** type, OS, browser fingerprint
- **Network context:** IP reputation, VPN/proxy usage
- **Temporal patterns:** login hour, session frequency
- **Behavioral patterns:** variance in location/device, anomaly history

All categorical features are encoded numerically, and numerical values are normalized using Min-Max scaling. These features are later used in a layered scoring pipeline to compute Initial, Behavioral, and Dynamic Risk Scores, which guide the final classification process. Correlation patterns among risk-related features align with risk semantics (omitted for space).

#### C. Risk Score Calculation

We calculate an **Initial Risk Score (IRS)** by combining static indicators:

- Use of VPN, proxy, or Tor
- Suspicious IPs (e.g., unusual subnets)
- Login at unusual hours
- Failed attempts or brute-force behavior
- Mismatches in fingerprint, timezone, or geolocation

Each signal contributes a weighted risk value, and the total is capped at 1.0. See Fig. 2.

To further analyze static risk signals, we examine the number of triggered flags per session. Most sessions raise one or no static flags, while a minority accumulate multiple suspicious signals, indicating elevated risk (summary omitted for space).

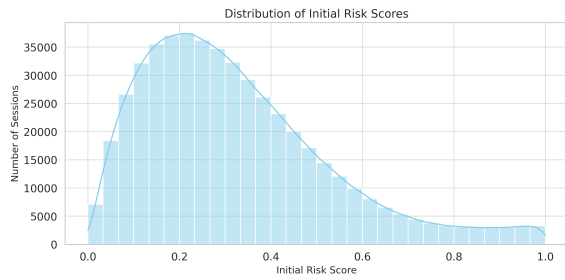


Fig. 2. Distribution of Initial Risk Scores

#### D. Anomaly Detection

Sessions are flagged as anomalous when at least three predefined behavioral heuristics are met. These include geolocation jumps, login attempts from high-risk regions, or rare user agents. The class imbalance is shown in Fig. 3.

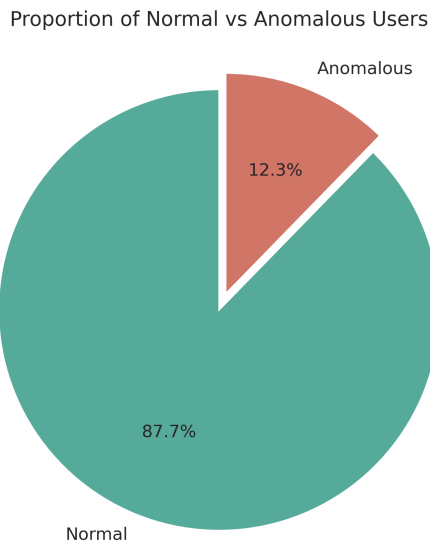


Fig. 3. Normal vs Anomalous Sessions

#### E. Behavioral Score (BS)

To quantify behavioral consistency, a normalized score is computed for each session. Penalties are assigned for unusual device types, inconsistent locations, irregular login times, or low activity history. Fig. 4 shows the BS distribution.

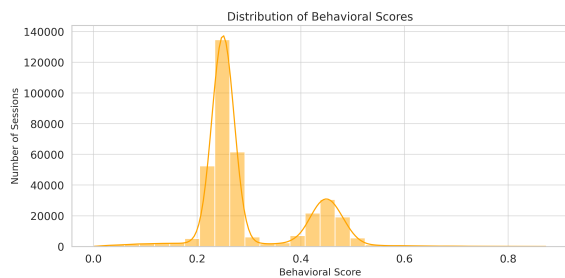


Fig. 4. Distribution of Behavioral Scores

#### F. Dynamic Risk Score

The final **Dynamic Risk Score** is a weighted combination:

$$\text{DRS} = 0.5 \cdot \text{IRS} + 0.3 \cdot (1 - \text{BS}) + 0.2 \cdot \text{Anomaly} \quad (1)$$

*Rationale.* We prioritize technical risk (IRS, 0.5), penalize behavioral drift (1-BS, 0.3), and add a binary anomaly safeguard (0.2).

**Ablation (weights).** On the validation set, (0.5, 0.3, 0.2) maximized macro-F1 ( $\approx 0.99$ ) with a reasonable challenge rate ( $\approx 0.21$ ), while (0.4, 0.4, 0.2) and (0.6, 0.2, 0.2) slightly degraded macro-F1 ( $\approx 0.98$ ) or shifted the challenge rate ( $\approx 0.25 / \approx 0.18$ ).

### IV. RESULTS AND DISCUSSION

#### A. Performance Evaluation

Our ML-based RBA framework demonstrated strong classification performance across a diverse set of models. Ensemble methods—particularly **Random Forest**, **Gradient Boosting**, and **AdaBoost**—achieved high F1-scores and AUC (Area Under the Receiver Operating Characteristic Curve), confirming their effectiveness in capturing both behavioral and contextual risk indicators. Traditional classifiers such as **Naive Bayes** and **K-Nearest Neighbors** underperformed, likely due to their limited capacity to model complex and imbalanced feature spaces.

Unless otherwise stated, metrics are reported on a stratified 20% hold-out test split (F1  $\approx 0.99$ , AUC  $\approx 0.99$ ). In addition, 5-fold stratified cross-validation yields mean F1  $\approx 0.98$  with low variance ( $\pm 0.01$ ), confirming consistent generalization.

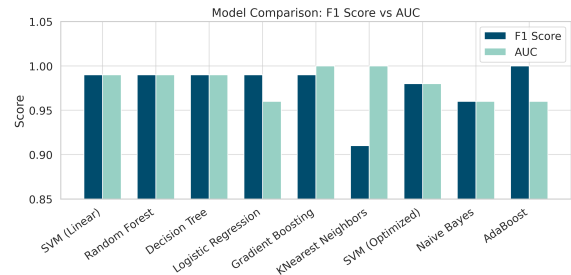


Fig. 5. F1 and AUC across models. Ensemble methods consistently lead.

#### B. Dynamic Risk Score Alignment

The DRS reflects layered risk estimation. As shown in Fig. 6, sessions labeled **Block** consistently exhibit higher DRS values, while **Allowed** sessions cluster around lower scores. This confirms the score's ability to guide reliable access decisions.

#### C. Risk Score Clustering

Fig. 7 illustrates the distributions of **IRS**, **BS**, and **DRS**. Unlike prior approaches that rely on static or binary signals, our framework combines multiple dimensions to capture richer risk semantics. This multi-layered view reveals clearer separations between **Allowed**, **Challenge**, and **Block** sessions, enabling better discrimination of borderline cases.

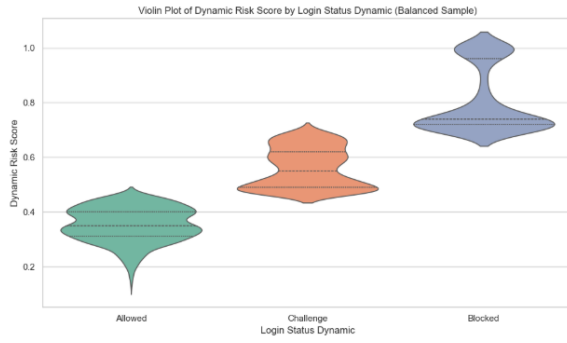


Fig. 6. DRS Distributions by Login Status

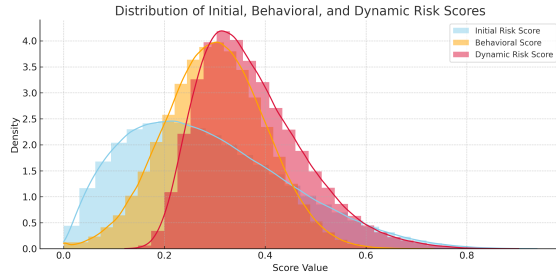


Fig. 7. Distributions of IRS, BS, and DRS

#### D. Confusion Matrix Analysis

The confusion analysis confirms strong multi-class prediction with minimal misclassifications; our Random Forest cleanly separates the three access decisions (Fig. 8).

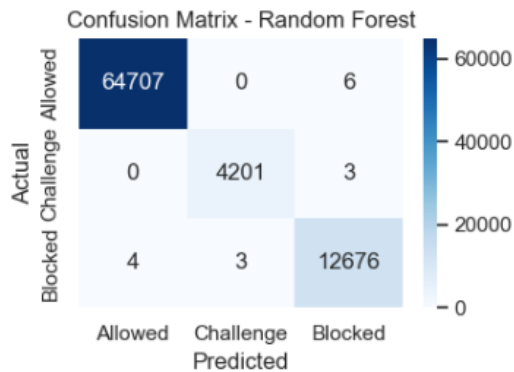


Fig. 8. Confusion matrix for our model (Random Forest) on the synthetic IoT dataset.

Notably, the model correctly identified nearly all **Block** sessions; residual errors mainly occur between **Allow** and **Challenge** for borderline DRS values.

#### E. Baseline Comparison

For a fair three-class comparison, we derive the **Challenge** class for the binary baseline by thresholding its decision score: low-risk  $\rightarrow$  Allow, high-risk  $\rightarrow$  Block, and an intermediate band  $\rightarrow$  Challenge. This mapping explains the observed Allow/Challenge confusions in Fig. 11.

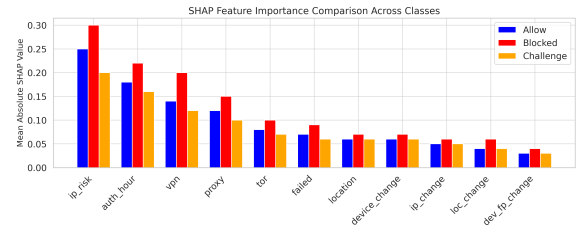
We compared our framework with the GitHub baseline by Gholamrezaei [11]. Table II summarizes architectural and dataset differences; performance is captured in Fig. 5.

TABLE II  
COMPARISON BETWEEN BASELINE AND OUR PIPELINE

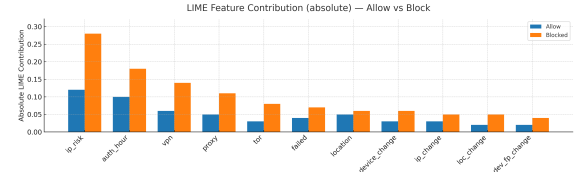
| Aspect            | Baseline    | Our Pipeline    |
|-------------------|-------------|-----------------|
| Risk Scoring      | Static only | Multi-layered   |
| Anomaly Detection | Absent      | Heuristic-based |
| Model Variety     | LR, RF      | 8 classifiers   |
| Dataset Size      | 10k samples | 500k sessions   |

#### F. Explainability (SHAP and LIME)

At a global level (SHAP), features like `ip_risk`, `auth_hour`, and the use of `vpn/proxy/tor` dominate **Block** predictions and have lower impact for **Allow**. Locally (LIME), the same signals explain individual blocked/allowed decisions. Fig. 9 combines the global (SHAP) and the complementary local (LIME) views for interpretability.



(a) SHAP multi-class (Allow/Challenge/Blocked)



(b) LIME – local contributions (Allow vs Blocked)

Fig. 9. Combined explainability: (a) global SHAP per class, (b) local LIME on representative sessions. High-risk signals (`ip_risk`, `auth_hour`, `vpn/proxy/tor`) align with the DRS design.

#### G. Threats to Validity

While our framework performed well under simulation, some limitations must be acknowledged:

- **Simulated Data:** As already discussed, synthetic datasets may inflate performance scores.
- **Overfitting Risk:** Near perfect scores ( $F1 \approx 0.99$ ) may not generalize to noisy, real-world data.
- **Deployment Constraints:** Edge deployment remains untested.

These limitations motivate real-world validation in future work.

### H. Real-World Evaluation on Public IoT Data

We evaluated a baseline Random Forest on the TON\_IoT Thermostat dataset [12], which contains over 440,000 labeled thermostat records. Only two features (current temperature, thermostat state) were available, i.e., no contextual or behavioral risk indicators. The model reached **Accuracy**  $\approx 0.80$ , **Macro-F1**  $\approx 0.51$ , with **F1 (attack)**  $\approx 0.14$  and **AUROC**  $\approx 0.51$  (Fig. 10). These results confirm that multi-layer risk signals (contextual, behavioral, anomaly) are essential for reliable attack detection.

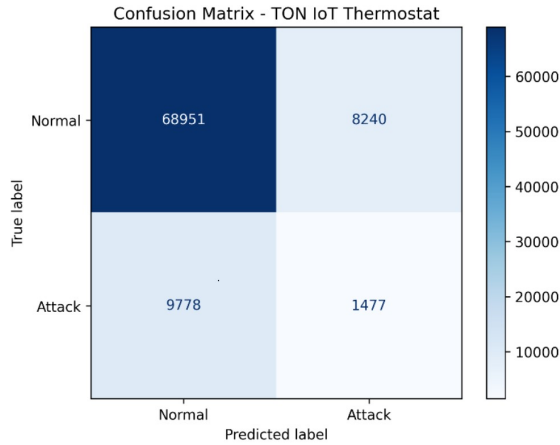


Fig. 10. Confusion Matrix for TON\_IoT Thermostat Dataset

**Scalability note.** In preliminary scaling tests, training time grew approximately linearly with dataset size, and per-session inference with tree ensembles remained sub-millisecond on a commodity CPU. This empirically supports the claim of scalability under increasing numbers of IoT sessions/devices.

### V. COMPARATIVE ANALYSIS

We benchmarked our framework against the GitHub baseline by Gholamrezaei [11], which performs binary classification using static features and conventional models (Logistic Regression, Random Forest). However, it lacks key mechanisms such as behavioral modeling, multi-layered scoring, and explainability—essential for robust IoT authentication.

Our system introduces three key innovations: (1) tri-level access decisions (**Allow**, **Challenge**, **Block**), (2) a layered scoring mechanism combining IRS, BS, and anomaly flags, and (3) SHAP-based explainability for transparency.

Table III highlights the architectural differences.

As for the GitHub baseline, the confusion matrix highlights frequent confusion between Allow and Challenge (Fig. 11), consistent with the lack of behavioral/contextual layers.

Fig. 5 shows the F1-score and AUC comparison across all classifiers. Our enhanced system outperforms the baseline, especially on ensemble models (Random Forest, Gradient Boosting, AdaBoost).

**Note.** Although the baseline was designed for binary classification (**Allow** vs **Block**), we mapped its outputs into a three-class setting (**Allow**, **Challenge**, **Block**) for comparative purposes.

TABLE III  
BASELINE VS OUR FRAMEWORK

| Aspect            | Baseline             | Our Framework                       |
|-------------------|----------------------|-------------------------------------|
| Risk Levels       | Binary (Allow/Block) | Multi-class (Allow/Challenge/Block) |
| Anomaly Detection | None                 | Yes (Heuristic-based)               |
| Behavioral Score  | Not used             | Integrated                          |
| Accuracy          | 0.97                 | $\approx 0.99$                      |
| F1-Score          | 0.95                 | $\approx 0.99$                      |
| Dataset Size      | 10k                  | 500k synthetic sessions             |
| Device Modeling   | Absent               | IoT-aware                           |

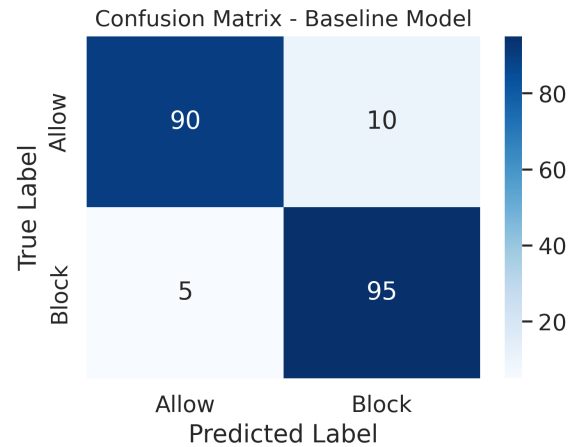


Fig. 11. Confusion Matrix for Baseline Model

### VI. CONCLUSION AND FUTURE WORK

This paper introduced a multi-layered RBA framework for IoT environments, combining initial technical indicators, behavioral patterns, and anomaly signals into a unified Dynamic Risk Score (DRS). Trained and evaluated on a synthetically generated dataset of 500,000 labeled login sessions, the approach achieved near-perfect performance (F1, AUC  $\approx 0.99$ ). In addition, preliminary scaling tests (omitted for space) showed approximately linear training time with dataset size and sub-millisecond per-session inference on a commodity CPU, which substantiates our scalability claim. Unlike static or binary RBA strategies, our layered and behavior-driven design enables more accurate, adaptive, and explainable authentication decisions across the three risk levels (**Allow/Challenge/Block**).

**Limitations.** The current evaluation relies primarily on synthetic data and a limited-feature public dataset, which may not capture all real-world complexities. Real-time constraints and embedded deployments have not yet been assessed.

#### Future Work.

- Validation on richer, real-world IoT datasets (e.g., BoT-IoT, additional TON\_IoT subsets).
- On-device/edge integration (e.g., Raspberry Pi, ESP32) with latency, energy, and model-size benchmarks.
- Adaptive thresholding and policy tuning via feedback or reinforcement learning.

- Inference-time explainability dashboards leveraging SHAP/LIME.
- Longitudinal evaluation under behavioral drift and seasonal patterns (concept drift), with streaming data, to assess robustness over time.

## ACKNOWLEDGMENT

We sincerely thank Dr. Mohamad Jaafar Ali, our project advisor, for his dedicated supervision, insightful guidance, and continuous support throughout the development of this work. We also express our gratitude to Prof. Osman Salem and Prof. Ahmed Mehaoua from Université Paris Cité for their valuable feedback and academic contributions, which significantly enriched the quality and direction of this project.

## REFERENCES

- [1] D. Florêncio and C. Herley, 'A large-scale study of web password habits,' in *Proc. 16th Int. Conf. World Wide Web*, 2007, pp. 657–666.
- [2] J. Bonneau, C. Herley, P. C. van Oorschot, and F. Stajano, 'The quest to replace passwords: A framework for comparative evaluation of web authentication schemes,' in *Proc. IEEE Symp. Security and Privacy*, 2012, pp. 553–567.
- [3] M. Amin, M. A. Khan, and M. I. Khan, 'Secure biometric authentication scheme for smart environments using elliptic curve cryptography,' *J. Netw. Comput. Appl.*, vol. 95, pp. 325–338, 2017.
- [4] X. Yang, Y. Qiao, and S. Xu, 'Context-aware authentication based on behavioral biometrics for mobile devices,' *IEEE Trans. Inf. Forensics Security*, vol. 13, no. 12, pp. 3074–3086, 2018.
- [5] L. Fridman, S. Weber, R. Greenstadt, and M. Kam, 'Active authentication on mobile devices via stylometry, application usage, web browsing, and GPS location,' *IEEE Syst. J.*, vol. 11, no. 2, pp. 513–521, 2017.
- [6] H. Rathore, A. A. Sangaiah, and D. Gupta, 'An efficient data collection technique for mobile wireless sensor networks using compressive sensing,' *IEEE Trans. Ind. Informat.*, vol. 14, no. 4, pp. 1624–1632, 2018.
- [7] Y. Mirsky, T. Doitsman, Y. Elovici, and A. Shabtai, 'Kitsune: An ensemble of autoencoders for online network intrusion detection,' in *Proc. NDSS Symp.*, 2018.
- [8] I. Wiefeling, S. Werner, M. Busch, and M. Mühlhäuser, 'Is risk-based authentication broken? Revisiting account security in the wild,' in *Proc. IEEE Symp. Security and Privacy (SP)*, 2021, pp. 496–512.
- [9] T. Dierks, 'TLS authentication and key material exporters,' *IETF RFC 5705*, Mar. 2010.
- [10] A. Greenberg, 'Hackers Remotely Kill a Jeep on the Highway,' *Wired*, Jul. 2015. [Online]. Available: <https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/>
- [11] M. Gholamrezaei, 'Risk-based authentication with machine learning,' GitHub Repository, 2023. [Online]. Available: <https://github.com/gholamrezaei/rba-ml>
- [12] A. M. Moustafa et al., 'TON\_IoT Telemetry and Network Datasets,' UNSW Canberra, 2020.
- [13] S. M. Lundberg and S.-I. Lee, 'A Unified Approach to Interpreting Model Predictions,' *NeurIPS*, 2017.
- [14] M. T. Ribeiro, S. Singh, and C. Guestrin, 'Why Should I Trust You?' Explaining the Predictions of Any Classifier, *KDD*, 2016.